# Consent Is Not a Constitution: The DPDP Act and the Missing Proportionality Test

*Subhashis Banerjee/ Computer Science and Centre for Digitalisation, AI, and Society, Ashoka University*

### From Puttaswamy to the DPDP Act

India's Digital Personal Data Protection Act, 2023 was meant to give statutory form to a constitutional promise. In *Justice K.S. Puttaswamy v Union of India* (2017), a nine-judge bench of the Supreme Court held privacy to be a fundamental right under Article 21. It did not stop at declaring the right. The plurality laid down how any state intrusion must be tested: there must be a law, the law must pursue a legitimate aim, and the intrusion must be proportionate to that aim. Proportionality asks whether the measure can achieve its purpose (suitability), whether a less intrusive alternative could achieve it adequately (necessity), and whether the benefits justify the infringement of rights (balancing). A useful purpose alone is not enough. Justice Kaul added that there must be procedural safeguards against abuse. The Court also urged the government to enact a data protection regime that would honour these standards (India 2023; Supreme Court of India 2017).

What followed took six years. The Srikrishna Committee's 2018 draft bill borrowed heavily from the GDPR. The 2019 bill widened state exemptions, and it was withdrawn in 2022 after a joint parliamentary committee review. The 2023 Act is a far leaner text. The DPDP Rules were notified in November 2025, with most substantive duties scheduled to take effect in May 2027. The question worth asking is whether it does what *Puttaswamy* required. On the central test, proportionality, it does not (Committee of Experts under the Chairmanship of Justice B. N. Srikrishna 2018; India 2019; India, Ministry of Electronics and Information Technology 2025).

The issue is not simply whether particular provisions of the DPDP Act, or schemes operating under it, would survive constitutional scrutiny. It is whether the legislation establishes an institutional obligation to demonstrate proportionality before intrusive data-processing systems are deployed.

### Two architectures

The DPDP Act is built around consent. A data fiduciary may process personal data with the data principal's consent, or for one of a closed list of "certain legitimate uses" in section 7. For private actors, that list is narrow, so consent does most of the work. For the state, the list is generous. Section 7(b) covers prescribed subsidies, benefits and services, subject to conditions concerning earlier consent or data in notified government records and applicable processing standards. It permits the present processing without fresh consent; earlier consent may supply one condition. Section 7(c) covers functions "under any law", and also processing in the interest of the sovereignty, integrity or security of the State, without expressly requiring a separate enabling law for that limb. Constitutional requirements still apply. Section 17(2)(a) lets the government exempt notified state instrumentalities from the Act on specified grounds. None of these provisions asks for a necessity or proportionality test (India 2023, secs. 7 and 17).

The GDPR starts somewhere else. It treats data protection as a fundamental right under the EU Charter. Consent is only one of six lawful bases; the appropriate basis depends on the processing. The structural difference lies in where proportionality sits. A public authority performing its tasks must point to a law that is clear, foreseeable and proportionate to its aim (Article 6(3)). It cannot rely on legitimate interests when performing those tasks. A private controller that relies on legitimate interests must first show necessity and then balance its interest against the data subject's rights. High-risk processing requires an impact assessment that weighs necessity and proportionality (Article 35). In both cases, proportionality is a condition of lawful processing, assessed before the data is touched (European Parliament and Council of the European Union 2016, arts. 6 and 35).

**Proportionality left to litigation**

The word "proportionality" does not appear in the DPDP Act. There is no general requirement for a published assessment showing that a state processing scheme is necessary and comparing less intrusive alternatives before deployment. Designated significant data fiduciaries, potentially including state bodies, must carry out periodic assessments, subject to exemptions. This is not a general mechanism for independent constitutional scrutiny in advance. The Data Protection Board is appointed by the central government, and it has no advisory role on legislation or executive notifications. It adjudicates breaches of the Act's specific duties after they occur.

The Act therefore relies on ex-post accountability. A fiduciary is to give notice and take consent where required, keep data secure and report breaches, and the Board can penalise failures. The *Puttaswamy* test is not repealed by this design; it is simply left out. The constitutional obligation to justify an intrusion already binds the state; it does not begin with litigation. But without mandatory advance documentation and scrutiny, citizens may have to discover and challenge a database, linkage or exemption themselves. Courts can review proposed measures as well as existing ones. Such adjudication cannot substitute for an institutional duty to publish and defend the justification before deployment.

**Compliance is not harm accountability**

Imagine a bank refuses someone a loan after using a profile assembled from several databases. A regulator can check whether the bank followed the rules for collecting and processing personal data, and penalise it for any violations, even if no one suffered demonstrable harm. But what if the bank complied with all these rules, yet rejected the application because of an invalid AI-based inference drawn from the combined data? Establishing that the inference was invalid—and holding the bank accountable for it—would be much harder.

Two kinds of accountability must be distinguished. Compliance accountability asks whether a fiduciary violated a statutory duty; a regulator can establish a failure of notice or security without proving injury to any individual. Harm accountability asks whether particular processing caused an adverse consequence. With personal data, that causal chain of inference is often invisible. Someone denied a loan, flagged for a welfare investigation, or targeted by a scam may never discover which linkage, inference or disclosure contributed to the decision. Harms may surface months later, elsewhere.

The Act provides compliance penalties, but no compensation under its own framework; penalties go to the state. Processors are regulated principally through fiduciaries, while the relevant data flows may remain opaque to outsiders. Crucially, even perfect enforcement of notice, consent and security duties cannot establish that an otherwise compliant scheme is necessary or proportionate. The Dutch SyRI and childcare-benefits scandals illustrate how problematic profiling systems may require scrutiny by courts, journalists and civil society. Compliance enforcement is indispensable, but cannot substitute for scrutiny of the processing itself (Rechtbank Den Haag 2020; Autoriteit Persoonsgegevens 2021).

**Consent is not authorisation**

Three questions must be separated. Is this use of data justified? Who may access which data, and for what operation? Has the person validly agreed? Legitimacy asks whether processing for a stated purpose is justified by law, necessity and proportionality, with the applicable legal test depending on the actor and context. Authorisation asks whether a particular actor may access particular data for a particular operation, under an enforceable and auditable policy. Consent asks whether an individual has validly agreed, where agreement is an appropriate legal basis. Consent may be an input to authorisation; it cannot establish legitimacy. Nor does authorisation alone establish legitimacy. A consent artefact specifying "loan underwriting" does not demonstrate that every requested datum is necessary, or control all subsequent inferences and linkages. A system can be consent-compliant yet disproportionate, or legitimate in purpose yet insecure in its access controls.

Over-reliance on consent also ignores the conditions in which it is obtained. Individuals rarely know what linked data can reveal or have power to negotiate terms. When consent is effectively the price of a loan or treatment, formal agreement may conceal coercion. The GDPR explicitly scrutinises imbalance of power and conditioning a service on unnecessary processing. The DPDP Act requires free and specific consent, but does not provide an equally developed framework for assessing such structural imbalances (Solove 2013; European Parliament and Council of the European Union 2016, art. 7 and recital 43; India 2023, sec. 6).

For public services, the point is sharper still. A welfare scheme, a health record or an identity system should rest on a specific law that states its purpose, its data and its limits. It must not violate people's rights even if they consent. Consent cannot make a disproportionate scheme proportionate. Hiding behind consent is not a principled option.

**The case for documented ex-ante proportionality**

The alternative is to do what *Puttaswamy* asked, and to do it before deployment. Every significant or intrusive state processing scheme should be supported by a proportionality analysis that is written down and published before it goes live. That analysis would state the purpose and the law that authorises it. It would show that the system can actually achieve the purpose, set out the less intrusive alternatives that were considered, and specify what data is collected, who can access it, which systems it is linked to, and for how long it is kept. It should be reviewed by a body that is independent of the department proposing the scheme. Private high-risk processing should undergo proportionate, risk-based review irrespective of consent; this is a proposal for statutory governance, not a claim that every private non-consent use directly attracts the constitutional test for state action.

Consider a hypothetical proposal to link public-health records across hospitals to detect outbreaks earlier. Its assessment would identify the authorising law and require evidence of improved detection over existing reporting, perhaps from a limited pilot measuring detection times, missed cases and false alerts. It would compare linkage with aggregate reporting, fewer data fields and analysis within hospitals that shares only alerts. It would specify necessary records and identifiers, assess mistaken matches, sensitive disclosures and unrelated reuse, and identify who bears these risks. It would restrict identifiable access to authorised health staff, specify access logs, encryption, retention limits and correction procedures, and justify the remaining risks against evidenced benefits. If the evidence were inadequate, the scheme should be narrowed, redesigned or withheld.

Publication matters as much as the analysis itself. A published assessment can be contested before harm occurs, rather than reconstructed in court afterwards. It gives the Board and the courts a record against which to test later conduct. Above all, it makes the state's existing constitutional burden of justification an institutional requirement before deployment.

**Regulation is not the opposite of innovation**

It is tempting to dismiss ex-ante proportionality analysis as regulation standing in the way of innovation. "Innovation versus regulation" is a false dichotomy. A design that cannot contain the harms it creates is not particularly innovative; it simply shifts its costs onto the people whose data it processes. Proportionality analysis asks designers to state what a system is for, to show that it works, and to find the least intrusive way of achieving it. These are design questions, and answering them well is what good engineering looks like. Proportionality analysis and innovation can, and should, go hand in hand (Cohen 2013).

**Proportionality needs a grammar**

Proportionality is necessary, but it is not self-executing. In the Aadhaar judgment (2018), the majority and Justice Chandrachud's dissent applied the same test to the same scheme and reached opposite conclusions. The majority weighed benefits of deduplication and minimal data collection, and found the scheme proportionate. The dissent weighed exclusion from biometric failure and the architecture of surveillance, and found it unconstitutional. The GDPR's enforcement record—more than two thousand fines, running to several billion euros—also demonstrates that statutory obligations and controllers' own compliance assessments do not guarantee lawful processing (Supreme Court of India 2018; CMS 2026).

The lesson is that benefits and risks must be stated in a precise, common language. Claimed benefits need measurable outcomes and evidence that the system actually works. Risks need explicit threat models, the effects of linking datasets, error rates, and an account of who bears them. Without such a grammar, proportionality analysis becomes rhetoric, and whoever controls the narrative controls the outcome. The framework is right. Operationalising it requires a precise way of articulating risk. Developing such a grammar—and a way of testing the evidence on which proportionality claims rest—is the subject of a future article.

**References**


Autoriteit Persoonsgegevens. 2021. “Tax Administration Fined for Discriminatory and Unlawful Data Processing.” December 7.

CMS. 2026. “Numbers and Figures.” *GDPR Enforcement Tracker Report 2026*. May 21.

Cohen, Julie E. 2013. “What Privacy Is For.” *Harvard Law Review* 126 (7): 1904–33.

Committee of Experts under the Chairmanship of Justice B. N. Srikrishna. 2018. *Personal Data Protection Bill, 2018.* Draft. Ministry of Electronics and Information Technology, Government of India. Reproduced by The Hindu Centre for Politics and Public Policy, July 31.

European Parliament and Council of the European Union. 2016. “Regulation (EU) 2016/679 of 27 April 2016 (General Data Protection Regulation).” *Official Journal of the European Union* L 119 (May 4): 1–88.

India. 2019. *The Personal Data Protection Bill, 2019.* Bill No. 373 of 2019. Lok Sabha. Reproduced by PRS Legislative Research.

India. 2023. *The Digital Personal Data Protection Act, 2023.* Act No. 22 of 2023. August 11.

India. Ministry of Electronics and Information Technology. 2025. “Digital Personal Data Protection Rules, 2025.” *Gazette of India*, Extraordinary, Part II, section 3(i), G.S.R. 846(E), November 13.

Rechtbank Den Haag. 2020. “SyRI Legislation in Breach of European Convention on Human Rights.” Rechtspraak, February 13.

Solove, Daniel J. 2013. “Introduction: Privacy Self-Management and the Consent Dilemma.” *Harvard Law Review* 126 (7): 1880–1903.

Supreme Court of India. 2017. *Justice K. S. Puttaswamy (Retd.) and Another v. Union of India and Others.* Judgment, August 24. Writ Petition (Civil) No. 494 of 2012. Indian Kanoon.

Supreme Court of India. 2018. *Justice K. S. Puttaswamy (Retd.) v. Union of India.* Judgment, September 26. Writ Petition (Civil) No. 494 of 2012. Indian Kanoon.